

**Benemérita Universidad Autónoma
de Puebla**

Facultad de Ciencias de la Computación

Intercomunicación y seguridad en redes

Proyecto Final: RED TEAM VS BLUE TEAM



Docente: Ana Claudia Zenteno Vazquez

Alumno Méndez Méndez Brandon

202130905

Primavera 2026

Índice

1. Introducción.....	4
2. Planteamiento del Problema.....	4
3. Objetivos.....	5
3.1 Objetivo General.....	5
3.2 Objetivos Específicos.....	5
4. Marco Teórico.....	6
4.1 Ciberseguridad.....	6
4.2 Red Team.....	6
4.3 Blue Team.....	7
4.4 Hardening.....	7
4.5 Virtualización.....	8
4.6 Ubuntu Server.....	8
4.7 Kali Linux.....	9
4.8 Secure Shell (SSH).....	9
4.9 File Transfer Protocol (FTP).....	10
4.10 Domain Name System (DNS).....	10
4.11 Firewall.....	11
4.12 Fail2ban.....	11
4.13 Nmap.....	12
4.14 Hydra.....	12
4.15 Monitoreo y Análisis de Logs.....	12
5. Desarrollo del Proyecto.....	13
5.1 FASE 1 – Configuración de Máquinas Virtuales.....	13
5.1.1 Creación de la Máquina Virtual Ubuntu Server.....	13
5.1.2 Creación de la Máquina Virtual Kali Linux.....	14
5.1.3 Diseño Inicial del Entorno Virtual.....	15
5.1.4 Objetivo de la Fase.....	15
5.2 FASE 2 - Configuración de Red en Ubuntu Server.....	16
5.2.1 Configuración de Interfaces de Red.....	16
5.2.2 Configuración de Subredes y Enrutamiento.....	17
5.2.3 Configuración de Kali Linux.....	18
5.3 FASE 3: Instalación de Servicios Vulnerables.....	19
5.3.1 Instalar y Configurar SSH (Vulnerable).....	19
5.3.2 Instalar Servidor HTTP Vulnerable (Lighttpd).....	20
5.3.3 Instalar FTP Vulnerable (vsftpd).....	21
5.3.4 Instalar DNS (Bind9).....	22
5.3.5 Instalar Base de Datos MySQL.....	24
5.4 FASE 4: Documentación de Servicios.....	25
5.5 FASE 5: Actividades Red Team (Desde Kali Linux).....	26
5.5.1 Escaneo de Puertos y Enumeración.....	26

5.5.2 Enumeración de SSH.....	28
5.5.3 Fuerza Bruta con Hydra.....	28
5.5.4 Enumeración Web.....	29
5.5.5 Explotación DNS.....	29
5.5.6 Análisis y Conclusión de la fase 5.....	30
5.6 FASE 6: Actividades Blue Team (En Ubuntu Server).....	31
5.6.1 Implementar Firewall con iptables.....	31
5.6.2 Instalar y Configurar Fail2ban.....	31
5.6.3 Hardening de SSH.....	32
5.6.4 Monitoreo de Logs.....	32
5.6.5 IDS Básico (AIDE).....	33
5.7 FASE 7: Pruebas y Evidencias.....	33
5.7.1 Prueba de Conectividad.....	33
5.7.2 Registrar Evidencias.....	34
5.8 FASE 8: Análisis y Documentación Final.....	35
5.8.1 Informe de Efectividad.....	35
5.8.1.1 Escenarios evaluados.....	35
5.8.1.2 Métricas de mejora.....	35
5.8.2 Diagrama de Red.....	36
7. Resultados obtenidos.....	36
7.1 Resultados de Configuración de Infraestructura.....	37
7.2 Resultados de Escaneo y Enumeración.....	37
7.2.1 Servicios Detectados Mediante Nmap.....	37
7.3 Resultados de Fuerza Bruta.....	38
7.4 Resultados de Enumeración DNS.....	38
7.4.1 Subdominios Descubiertos Mediante Zone Transfer.....	38
7.5 Resultados de Implementación Blue Team.....	39
7.5.1 Medidas Defensivas Implementadas.....	39
7.6 Resultados de Hardening.....	39
7.6.1 Comparativa Antes y Después del Hardening.....	39
7.7 Métricas Globales del Proyecto.....	40
7.7.1 Métricas de Seguridad Obtenidas.....	40
8. Análisis de Resultados.....	40
9. Conclusiones.....	41
10. Bibliografía.....	43

1. Introducción

En la actualidad, la ciberseguridad se ha convertido en un elemento fundamental para la protección de la información y la continuidad operativa de organizaciones públicas y privadas. El crecimiento de las redes, los servicios expuestos a Internet y la dependencia de sistemas informáticos ha incrementado significativamente los riesgos relacionados con accesos no autorizados, robo de información, ataques de fuerza bruta y explotación de vulnerabilidades en servicios mal configurados.

Muchos incidentes de seguridad ocurren debido a configuraciones inseguras, uso de contraseñas débiles, falta de monitoreo y ausencia de mecanismos de defensa adecuados. Dentro del ámbito de la ciberseguridad, los enfoques Red Team y Blue Team permiten simular escenarios reales de ataque y defensa. El Red Team tiene como objetivo identificar y explotar vulnerabilidades mediante técnicas de reconocimiento, enumeración y explotación controlada, mientras que el Blue Team se encarga de implementar mecanismos de protección, monitoreo y respuesta ante incidentes para fortalecer la seguridad de la infraestructura.

El presente proyecto consiste en la implementación de un entorno de simulación Red Team vs Blue Team sobre infraestructura Linux virtualizada, utilizando máquinas virtuales Ubuntu Server y Kali Linux. En dicho entorno se configuraron diversos servicios vulnerables, incluyendo SSH, FTP, DNS, HTTP y MySQL, con el propósito de realizar pruebas controladas de reconocimiento y ataque mediante herramientas como Nmap, Hydra, Dirb y Dig.

Posteriormente, se aplicaron mecanismos de defensa y hardening, incluyendo reglas de firewall con iptables, bloqueo automático de ataques mediante Fail2ban, monitoreo de logs y fortalecimiento de configuraciones críticas del sistema. Finalmente, se realizó un análisis comparativo entre el estado inicial y el estado posterior al hardening, evaluando la efectividad de las medidas implementadas para reducir la superficie de ataque y mejorar la seguridad general de la infraestructura.

Este proyecto permite comprender de manera práctica la importancia de la defensa en profundidad, el monitoreo continuo y la correcta configuración de servicios en sistemas Linux, además de reforzar conocimientos relacionados con administración de redes, seguridad ofensiva y seguridad defensiva.

2. Planteamiento del Problema

Actualmente, muchas organizaciones dependen de infraestructuras tecnológicas para almacenar información, administrar servicios y mantener la comunicación entre

usuarios y sistemas. Sin embargo, una gran cantidad de servidores y servicios son desplegados con configuraciones inseguras o predeterminadas, lo que incrementa considerablemente el riesgo de sufrir ataques informáticos.

Problemas como el uso de contraseñas débiles, servicios expuestos innecesariamente, configuraciones vulnerables en SSH, FTP o DNS, ausencia de firewalls y falta de monitoreo de eventos de seguridad representan puntos críticos que pueden ser aprovechados por atacantes para comprometer sistemas y obtener acceso no autorizado.

Asimismo, la falta de prácticas de hardening y mecanismos automáticos de detección y bloqueo dificulta la identificación temprana de ataques como fuerza bruta, enumeración de servicios o exploración de vulnerabilidades.

Debido a esta problemática, surge la necesidad de implementar entornos de prueba que permitan analizar vulnerabilidades reales, comprender las técnicas utilizadas por los atacantes y evaluar la efectividad de mecanismos defensivos. Mediante una simulación controlada de actividades Red Team y Blue Team es posible identificar debilidades en la infraestructura, aplicar medidas correctivas y fortalecer la seguridad de los servicios implementados.

Por ello, en este proyecto se plantea el desarrollo de un laboratorio de ciberseguridad basado en Linux, en el cual se implementen servicios vulnerables para posteriormente realizar actividades de reconocimiento, enumeración y ataque controlado, así como la aplicación de técnicas de hardening, monitoreo y defensa que permitan reducir los riesgos de seguridad presentes en la infraestructura.

3. Objetivos

3.1 Objetivo General

Implementar un entorno de simulación Red Team vs Blue Team sobre infraestructura Linux virtualizada para identificar vulnerabilidades en servicios de red, ejecutar pruebas de ataque controladas y aplicar mecanismos de defensa y hardening que permitan fortalecer la seguridad del sistema.

3.2 Objetivos Específicos

- Configurar un entorno virtualizado utilizando Ubuntu Server y Kali Linux para la simulación de escenarios de ciberseguridad.

- Implementar servicios de red vulnerables como SSH, FTP, DNS, HTTP y MySQL para analizar riesgos de seguridad en una infraestructura Linux.
- Realizar actividades de reconocimiento, enumeración y análisis de vulnerabilidades mediante herramientas de seguridad ofensiva como Nmap, Hydra, Dirb y Dig.
- Ejecutar pruebas de fuerza bruta y técnicas de explotación controlada para evaluar el impacto de configuraciones inseguras en los servicios implementados.
- Aplicar mecanismos de defensa y hardening mediante firewall con iptables, configuración segura de SSH y bloqueo automático de ataques con Fail2ban.
- Implementar tareas de monitoreo y análisis de logs para detectar intentos de intrusión y actividades sospechosas dentro del sistema.
- Comparar el estado de seguridad de la infraestructura antes y después de aplicar las medidas de protección implementadas.
- Analizar la efectividad de las medidas defensivas aplicadas para reducir la superficie de ataque y mejorar la seguridad general de la infraestructura Linux.

4. Marco Teórico

4.1 Ciberseguridad

La ciberseguridad es el conjunto de prácticas, tecnologías, procesos y mecanismos diseñados para proteger sistemas informáticos, redes, dispositivos y datos frente a accesos no autorizados, ataques maliciosos, robo de información o daños en la infraestructura tecnológica. Su principal objetivo es garantizar la confidencialidad, integridad y disponibilidad de la información.

La ciberseguridad no solo implica la protección técnica de los sistemas, sino también la implementación de políticas, monitoreo constante y buenas prácticas de administración que permitan reducir la superficie de ataque y responder de manera eficiente ante incidentes de seguridad.

4.2 Red Team

El Red Team es un enfoque ofensivo dentro de la ciberseguridad cuyo objetivo es simular ataques reales contra una infraestructura tecnológica con el fin de identificar vulnerabilidades y debilidades de seguridad. Los integrantes del Red Team actúan como atacantes éticos utilizando herramientas y técnicas similares a las empleadas por ciberdelincuentes.

Las actividades de un Red Team incluyen reconocimiento, enumeración de servicios, análisis de vulnerabilidades, explotación controlada y obtención de acceso a sistemas. Estas pruebas permiten evaluar el nivel de exposición de una infraestructura y determinar qué tan vulnerable es frente a ataques reales.

Dentro de las herramientas comúnmente utilizadas por un Red Team se encuentran Nmap para escaneo de puertos, Hydra para ataques de fuerza bruta, Dirb para enumeración web y Dig para consultas DNS.

La finalidad del Red Team no es causar daño, sino detectar fallas de seguridad que posteriormente puedan corregirse mediante mecanismos defensivos.

4.3 Blue Team

El Blue Team representa el enfoque defensivo de la ciberseguridad. Su función principal es proteger la infraestructura tecnológica mediante la implementación de controles de seguridad, monitoreo de eventos, análisis de logs y respuesta ante incidentes. De este modo trabaja en la identificación de actividades sospechosas, detección de ataques y fortalecimiento de configuraciones inseguras mediante técnicas de hardening y herramientas de protección.

Entre las actividades más importantes del Blue Team se encuentran:

- Configuración segura de servicios.
- Implementación de firewalls.
- Monitoreo de logs.
- Detección de intrusiones.
- Bloqueo automático de ataques.
- Análisis de vulnerabilidades.
- Aplicación de políticas de seguridad.

La combinación entre Red Team y Blue Team permite evaluar de forma práctica la efectividad de los mecanismos defensivos implementados en una infraestructura.

4.4 Hardening

El hardening, también conocido como endurecimiento de sistemas, es el proceso de aplicar configuraciones y medidas de seguridad destinadas a reducir vulnerabilidades y minimizar la superficie de ataque de un sistema operativo o servicio.

El hardening incluye actividades como:

- Deshabilitar servicios innecesarios.
- Cambiar configuraciones predeterminadas.
- Implementar políticas de autenticación seguras.
- Restringir accesos.
- Actualizar software.
- Configurar firewalls.
- Monitorear eventos de seguridad.

La finalidad del hardening es dificultar que un atacante pueda comprometer el sistema mediante configuraciones débiles o servicios inseguros.

4.5 Virtualización

La virtualización es una tecnología que permite ejecutar múltiples sistemas operativos de forma independiente sobre un mismo equipo físico mediante máquinas virtuales. Cada máquina virtual posee recursos propios como memoria RAM, almacenamiento, interfaces de red y sistema operativo.

Herramientas como VirtualBox permiten crear entornos de laboratorio seguros para realizar pruebas de ciberseguridad sin afectar sistemas reales. Gracias a la virtualización es posible simular infraestructuras completas de ataque y defensa utilizando diferentes máquinas conectadas mediante redes virtuales.

En este proyecto, la virtualización permitió implementar un entorno controlado compuesto por una máquina atacante y una máquina víctima para realizar pruebas de seguridad ofensiva y defensiva.

4.6 Ubuntu Server

Ubuntu Server es una distribución Linux orientada a servidores y entornos empresariales. Se caracteriza por su estabilidad, soporte a largo plazo y amplia compatibilidad con servicios de red y herramientas de administración.

Ubuntu Server es ampliamente utilizado para alojar servicios como:

- SSH
- DNS
- HTTP
- FTP
- Bases de datos
- Firewalls

Además, ofrece herramientas de seguridad y monitoreo que permiten implementar configuraciones seguras y mecanismos de protección frente a ataques.

En este proyecto, Ubuntu Server fue utilizado como la máquina víctima sobre la cual se desplegaron los servicios vulnerables y posteriormente las medidas de hardening.

4.7 Kali Linux

Kali Linux es una distribución Linux especializada en pruebas de penetración y auditorías de seguridad informática. Incluye una gran cantidad de herramientas orientadas a análisis de vulnerabilidades, explotación, reconocimiento y pruebas ofensivas.

Entre las herramientas incluidas en Kali Linux destacan:

- Nmap
- Hydra
- Wireshark
- Dirb
- Metasploit
- Nikto

Kali Linux es ampliamente utilizado en entornos educativos y profesionales para realizar pruebas controladas de seguridad y evaluar infraestructuras tecnológicas.

En este proyecto, Kali Linux fue utilizado como máquina atacante dentro del entorno Red Team.

4.8 Secure Shell (SSH)

SSH (Secure Shell) es un protocolo de comunicación segura utilizado para acceder remotamente a sistemas mediante una conexión cifrada. SSH permite administrar servidores, ejecutar comandos y transferir archivos de manera segura.

El servicio SSH suele ejecutarse en el puerto 22/TCP y es uno de los servicios más utilizados en servidores Linux. Sin embargo, configuraciones inseguras pueden convertirlo en un objetivo frecuente de ataques de fuerza bruta y accesos no autorizados.

Entre las malas prácticas de seguridad en SSH se encuentran:

- Permitir acceso directo al usuario root.

- Uso de contraseñas débiles.
- Autenticación únicamente por contraseña.
- Falta de restricciones de conexión.

El hardening de SSH incluye el uso de autenticación por clave pública, deshabilitación del acceso root y limitación de intentos de autenticación.

4.9 File Transfer Protocol (FTP)

FTP (File Transfer Protocol) es un protocolo utilizado para la transferencia de archivos entre sistemas dentro de una red. Generalmente opera sobre el puerto 21/TCP.

Uno de los principales problemas de seguridad de FTP es que transmite información y credenciales en texto plano, lo que permite que un atacante pueda interceptar datos sensibles. Además, configuraciones inseguras como acceso anónimo o permisos excesivos incrementan significativamente el riesgo de compromiso.

En este proyecto se utilizó vsftpd como servidor FTP vulnerable para demostrar riesgos relacionados con:

- Acceso anónimo.
- Escritura de archivos.
- Contraseñas débiles.
- Enumeración de servicios.

4.10 Domain Name System (DNS)

DNS (Domain Name System) es el sistema encargado de traducir nombres de dominio a direcciones IP dentro de una red. Gracias al DNS, los usuarios pueden acceder a servicios utilizando nombres en lugar de direcciones numéricas.

Uno de los riesgos más comunes en servidores DNS es la transferencia de zona no restringida, también conocida como zone transfer. Esta vulnerabilidad permite que un atacante obtenga información completa sobre la estructura interna de dominios y subdominios.

La enumeración DNS proporciona información valiosa sobre servicios internos, servidores y posibles objetivos de ataque.

En este proyecto se implementó un servidor Bind9 vulnerable para demostrar el riesgo de permitir transferencias de zona a cualquier host.

4.11 Firewall

Un firewall es un mecanismo de seguridad encargado de controlar el tráfico de red entrante y saliente mediante reglas que permiten o bloquean conexiones específicas.

En sistemas Linux, una de las herramientas más utilizadas para la administración de firewalls es iptables. Esta herramienta permite:

- Filtrar tráfico.
- Bloquear conexiones.
- Permitir únicamente servicios autorizados.
- Registrar intentos de acceso.
- Limitar conexiones sospechosas.

La implementación de un firewall reduce considerablemente la superficie de ataque de un sistema y ayuda a prevenir accesos no autorizados.

4.12 Fail2ban

Fail2ban es una herramienta de seguridad utilizada para detectar y bloquear automáticamente direcciones IP que realizan múltiples intentos fallidos de autenticación.

Fail2ban analiza archivos de logs en busca de patrones sospechosos y aplica reglas temporales de bloqueo mediante firewall. Esta herramienta es ampliamente utilizada para proteger servicios como:

- SSH
- FTP
- Apache
- Nginx

Su principal ventaja es la automatización de la respuesta ante ataques de fuerza bruta, reduciendo considerablemente el riesgo de acceso no autorizado.

4.13 Nmap

Nmap (Network Mapper) es una herramienta de escaneo y enumeración utilizada para descubrir hosts, puertos abiertos, servicios y versiones dentro de una red.

Nmap permite realizar:

- Escaneo de puertos.
- Detección de servicios.
- Identificación de sistemas operativos.
- Enumeración de vulnerabilidades.
- Uso de scripts NSE para análisis avanzado.

Es una de las herramientas más utilizadas tanto en auditorías de seguridad como en actividades de reconocimiento ofensivo.

4.14 Hydra

Hydra es una herramienta utilizada para realizar ataques de fuerza bruta contra servicios de autenticación. Permite probar múltiples combinaciones de usuarios y contraseñas sobre diferentes protocolos.

Hydra soporta servicios como:

- SSH
- FTP
- HTTP
- MySQL
- Telnet

La herramienta es ampliamente utilizada para evaluar la robustez de políticas de autenticación y detectar credenciales débiles dentro de una infraestructura.

4.15 Monitoreo y Análisis de Logs

El monitoreo de logs consiste en analizar los registros generados por sistemas y servicios para detectar eventos sospechosos, errores, intentos de acceso no autorizados y actividades maliciosas.

Los logs representan una fuente fundamental de información dentro de la ciberseguridad, ya que permiten:

- Detectar ataques.

- Identificar fallos.
- Realizar auditorías.
- Analizar incidentes.
- Generar alertas.

En sistemas Linux, archivos como [/var/log/auth.log](#) contienen información relacionada con autenticaciones, intentos fallidos de acceso y eventos de seguridad.

El análisis constante de logs permite mejorar la capacidad de detección y respuesta frente a incidentes de seguridad.

5. Desarrollo del Proyecto

5.1 FASE 1 – Configuración de Máquinas Virtuales

La primera fase del proyecto consistió en la creación y configuración del entorno virtualizado que sería utilizado para la simulación de actividades Red Team y Blue Team. Para ello, se utilizó Oracle VirtualBox como plataforma de virtualización, permitiendo implementar un laboratorio controlado y aislado para realizar pruebas de ciberseguridad sin afectar sistemas reales.

La infraestructura estuvo compuesta por dos máquinas virtuales principales:

Máquina Virtual	Función	Sistema Operativo
Ubuntu_Server_BlueTeam	Víctima / Blue Team	Ubuntu Server 22.04 LTS
Kali_RedTeam	Atacante / Red Team	Kali Linux

La máquina Ubuntu Server fue utilizada como sistema víctima y entorno defensivo, mientras que Kali Linux fue utilizada para ejecutar herramientas ofensivas y pruebas de penetración.

5.1.1 Creación de la Máquina Virtual Ubuntu Server

Se creó una máquina virtual destinada a funcionar como servidor vulnerable dentro del laboratorio. La configuración asignada fue la siguiente:

Parámetro	Configuración
Nombre	Ubuntu_Server_BlueTeam
Sistema Operativo	Ubuntu Server 22.04 LTS
Memoria RAM	2048 MB
Disco Duro	25 GB dinámico
Adaptadores de Red	NAT + Red Interna
Usuario Principal	admin
Contraseña	Admin123!

La máquina virtual fue configurada con dos interfaces de red:

- Un adaptador NAT para acceso a Internet y descarga de paquetes.
- Un adaptador de red interna para la comunicación con Kali Linux dentro del laboratorio.

Durante la instalación del sistema operativo se habilitó OpenSSH Server con el objetivo de permitir acceso remoto y facilitar posteriormente las pruebas de seguridad relacionadas con el servicio SSH.

5.1.2 Creación de la Máquina Virtual Kali Linux

Posteriormente se creó una segunda máquina virtual basada en Kali Linux, la cual fue utilizada como estación atacante dentro del entorno Red Team.

La configuración utilizada fue la siguiente:

Parámetro	Configuración
Nombre	Kali_RedTeam
Sistema Operativo	Kali Linux
Memoria RAM	2048 MB
Disco Duro	30 GB
Adaptador de Red	Red Interna

Dirección IP	192.168.56.20/24
--------------	------------------

Kali Linux fue seleccionada debido a que incluye múltiples herramientas orientadas a auditorías de seguridad, análisis de vulnerabilidades y pruebas ofensivas. Entre las herramientas utilizadas posteriormente destacan:

- Nmap
- Hydra
- Dirb
- Dig
- Tcpdump

La máquina atacante fue conectada únicamente a la red interna del laboratorio para garantizar que las pruebas se realizarán dentro de un entorno aislado y controlado.

5.1.3 Diseño Inicial del Entorno Virtual

El laboratorio implementado permitió simular un escenario básico de infraestructura empresarial donde un atacante intenta identificar y explotar vulnerabilidades presentes en distintos servicios de red.

La arquitectura general del entorno estuvo conformada por:

- Un host físico con Windows.
- Una máquina Ubuntu Server actuando como servidor vulnerable.
- Una máquina Kali Linux actuando como atacante.
- Comunicación mediante red interna virtual.

La utilización de máquinas virtuales permitió:

- Repetir pruebas de seguridad de manera controlada.
- Restaurar configuraciones fácilmente.
- Evitar riesgos sobre sistemas reales.
- Simular escenarios prácticos de ataque y defensa.

5.1.4 Objetivo de la Fase

El objetivo principal de esta fase fue establecer la infraestructura base necesaria para el desarrollo del laboratorio Red Team vs Blue Team, garantizando que ambas máquinas virtuales contarán con los recursos y configuraciones necesarias para ejecutar posteriormente actividades de:

- Configuración de servicios.
- Escaneo de red.
- Enumeración.
- Fuerza bruta.
- Hardening.
- Monitoreo y defensa.

Esta fase representó el punto de partida para el resto de las actividades desarrolladas dentro del proyecto.

5.2 FASE 2 - Configuración de Red en Ubuntu Server

En esta fase se configuró la infraestructura de red para habilitar la comunicación entre el servidor y las máquinas de auditoría, garantizando además el acceso a Internet necesario para la gestión de paquetes y la ejecución de pruebas de penetración.

```
Shell
# Editar configuración de Netplan
sudo nano /etc/netplan/00-installer-config.yaml
```

```
None
network:
  version: 2
  ethernets:
    enp0s3: #Interfaz NAT (internet)
      dhcp4: true
    enp0s8: #Interfaz Red Interna
      dhcp4: no
      addresses:
        - 192.168.10.10/24
```

```
Shell
# Aplicar configuración
sudo netplan apply
# Verificar interfaces
ip addr show
ip route show
```

5.2.1 Configuración de Interfaces de Red

En esta fase se realizó la configuración de las interfaces de red del servidor mediante la herramienta Netplan, editando el archivo.

/etc/netplan/00-installer-config.yaml.

Se definieron dos interfaces de red con los siguientes propósitos:

La interfaz `enp0s3` se configuró para obtener su dirección IP automáticamente mediante DHCP, permitiendo la conexión a Internet a través de NAT.

La interfaz `enp0s8` se configuró con una dirección IP estática (**192.168.10.10/24**), destinada a la red interna para la comunicación con las máquinas de auditoría.

Una vez realizada la configuración, se aplicaron los cambios utilizando el comando `netplan apply`. Posteriormente, se verificó el estado de las interfaces y la tabla de enrutamiento mediante los comandos `ip addr show` e `ip route show`, confirmando la correcta conectividad de red.

5.2.2 Configuración de Subredes y Enrutamiento

```
Shell
# Crear subred virtual adicional (simulada)
sudo ip link add link enp0s8 name enp0s8.100 type vlan id 100
sudo ip addr add 10.0.100.1/24 dev enp0s8.100
sudo ip link set enp0s8.100 up
# Verificar enrutamiento
ip route show
route -n
```

En esta fase se realizó la creación de una subred virtual adicional mediante el uso de VLAN, con el objetivo de segmentar la red interna y simular un entorno más estructurado para las pruebas.

Para ello, se creó una interfaz virtual asociada a la interfaz física **enp0s8**, asignándole el identificador de VLAN 100. Posteriormente, se configuró una dirección IP (**10.0.100.1/24**) estática para permitir la comunicación dentro de esta nueva subred.

Una vez creada la interfaz, esta fue activada para su funcionamiento dentro del sistema.

Finalmente, se verificó la correcta configuración del enrutamiento mediante los comandos, **ip route show** y **route -n** confirmando que la nueva subred se encuentra correctamente registrada en la tabla de rutas del sistema.

5.2.3 Configuración de Kali Linux

Shell

```
# En Kali, configurar IP estática
sudo ip addr add 192.168.20.10/24 dev eth0
sudo ip link set eth0 up
# NOTA: Para que funcione la red interna, ambas VMs deben estar
# en el mismo segmento de red. Ajustemos la configuración:
```

Shell

```
# En Ubuntu Server:
sudo ip addr add 192.168.56.10/24 dev enp0s8
# En Kali Linux:
sudo ip addr add 192.168.56.20/24 dev eth0
```

En esta fase se configuró la interfaz de red de la máquina Kali Linux asignándole una dirección IP estática, con el objetivo de integrar a la red interna del laboratorio.

Inicialmente, se asignó la dirección IP **192.168.20.10/24** a la interfaz eth0, habilitando posteriormente dicha interfaz para su funcionamiento.

Sin embargo, se identificó que para garantizar la correcta comunicación dentro de la red interna, ambas máquinas virtuales deben pertenecer al mismo segmento de red.

Por lo tanto, se realizó una corrección en la configuración, asignando direcciones IP dentro de la misma subred (**192.168.56.0/24**), quedando de la siguiente manera:

Ubuntu Server (enp0s8): **192.168.56.10/24**

Kali Linux (eth0): **192.168.56.20/24**

Esta modificación permitió establecer una comunicación directa entre ambas máquinas, asegurando el correcto funcionamiento del entorno de pruebas.

5.3 FASE 3: Instalación de Servicios Vulnerables

5.3.1 Instalar y Configurar SSH (Vulnerable)

```
Shell ▾  
# Instalar SSH  
sudo apt update  
sudo apt install openssh-server -y
```

```
# Configurar SSH vulnerable  
sudo nano /etc/ssh/sshd_config
```

```
None  
Port 22  
PermitRootLogin yes  
PasswordAuthentication yes  
PermitEmptyPasswords yes  
Protocol 1 # Versión antigua vulnerable  
X11Forwarding yes
```

```
Shell  
# Configurar usuario con contraseña débil  
sudo useradd -m usuario_debil  
echo "usuario_debil:password123" | sudo chpasswd  
# Reiniciar SSH  
sudo systemctl restart ssh
```

En esta fase se realizó la instalación y configuración del servicio SSH en el servidor, con el propósito de simular un entorno vulnerable para pruebas de penetración.

En primer lugar, se instaló el servicio OpenSSH Server mediante el gestor de paquetes. Posteriormente, se modificó el archivo de configuración ubicado en **/etc/ssh/sshd_config** para habilitar opciones inseguras de manera intencional.

La configuración aplicada incluyó:

- Habilitación del acceso como usuario root (PermitRootLogin yes).
- Autenticación mediante contraseña (PasswordAuthentication yes).
- Permitir contraseñas vacías (PermitEmptyPasswords yes).

- Uso del protocolo SSH versión 1, considerado obsoleto y vulnerable (Protocol 1).
- Activación del reenvío X11 (X11Forwarding yes).

Adicionalmente, se creó un usuario con credenciales débiles (**usuario_debil/password123**), con el objetivo de facilitar la explotación durante las pruebas.

Finalmente, se reinició el servicio SSH para aplicar los cambios realizados.

Esta configuración permite simular un escenario realista de malas prácticas de seguridad, útil para la identificación y explotación de vulnerabilidades en entornos controlados.

5.3.2 Instalar Servidor HTTP Vulnerable (Lighttpd)

Shell

```
# Instalar Lighttpd (alternativa a Apache)
sudo apt install lighttpd -y
# Crear página vulnerable
sudo nano /var/www/html/index.html
```

HTML

```
<h1>Sistema de Administración Interna</h1>
```

Shell

```
# Instalar PHP para la vulnerabilidad
sudo apt install php-cgi -y
sudo lighty-enable-mod fastcgi
sudo lighty-enable-mod fastcgi-php
```

```
sudo systemctl restart lighttpd
```

En esta fase se realizó la instalación y configuración de un servidor web ligero utilizando Lighttpd, con el objetivo de simular un servicio HTTP vulnerable dentro del entorno de pruebas.

En primer lugar, se instaló el servidor web mediante el gestor de paquetes del sistema. Posteriormente, se creó una página web básica en la ruta `/var/www/html/index.html`, la cual representa un sistema interno de administración.

Adicionalmente, se instaló el soporte para PHP mediante el paquete **php-cgi**, permitiendo la ejecución de scripts dinámicos en el servidor web. Para ello, se habilitaron los módulos **fastcgi** y **fastcgi-php**, necesarios para la correcta integración de PHP con Lighttpd.

Finalmente, se reinició el servicio para aplicar los cambios realizados.

Esta configuración permite exponer un servicio web funcional con capacidades dinámicas, el cual puede ser utilizado para la identificación y explotación de vulnerabilidades en aplicaciones web dentro de un entorno controlado.

5.3.3 Instalar FTP Vulnerable (vsftpd)

Shell

```
# Instalar vsftpd (versión con vulnerabilidades conocidas)
sudo apt install vsftpd -y
# Configurar FTP vulnerable
sudo nano /etc/vsftpd.conf
```

None

```
anonymous_enable=YES
local_enable=YES
write_enable=YES
anon_upload_enable=YES
anon_mkdir_write_enable=YES
xferlog_enable=YES
```

Shell

```
# Crear directorio FTP con archivos falsos
sudo mkdir -p /var/ftp/pub
echo "datos_confidenciales_2024" | sudo tee
/var/ftp/pub/backup.txt
sudo chmod 777 /var/ftp/pub
sudo systemctl restart vsftpd
```

En esta fase se realizó la instalación y configuración de un servidor FTP utilizando vsftpd, con el objetivo de simular un servicio vulnerable para pruebas de seguridad.

En primer lugar, se instaló el servicio mediante el gestor de paquetes del sistema. Posteriormente, se modificó el archivo de configuración **/etc/vsftpd.conf** para habilitar múltiples opciones inseguras de forma intencional.

La configuración aplicada incluyó:

- Habilitación del acceso anónimo (anonymous_enable=YES).
- Permitir el acceso a usuarios locales (local_enable=YES).
- Habilitación de permisos de escritura (write_enable=YES).
- Permitir la subida de archivos por usuarios anónimos (anon_upload_enable=YES).
- Permitir la creación de directorios por usuarios anónimos (anon_mkdir_write_enable=YES).
- Activación del registro de transferencias (xferlog_enable=YES).

Adicionalmente, se creó un directorio accesible vía FTP en **/var/ftp/pub**, en el cual se almacenó un archivo simulado (**backup.txt**) con contenido sensible. A este directorio se le asignaron permisos amplios (777) para facilitar su acceso y manipulación.

Finalmente, se reinició el servicio para aplicar los cambios realizados.

Esta configuración permite simular un entorno con malas prácticas de seguridad en servicios FTP, facilitando la identificación y explotación de vulnerabilidades relacionadas con accesos no autorizados y exposición de información sensible.

5.3.4 Instalar DNS (Bind9)

```
Shell
# Instalar BIND9
sudo apt install bind9 -y
# Configurar zona vulnerable
sudo nano /etc/bind/named.conf.local
```

None

```
zone "empresa.internal" {  
    type master;  
    file "/etc/bind/db.empresa.internal";  
    allow-transfer { any; }; # Vulnerabilidad: transferencia de  
zona  
};
```

Shell

```
# Crear archivo de zona  
sudo nano /etc/bind/db.empresa.internal
```

None

```
$TTL 604800  
@ IN SOA ns1.empresa.internal. admin.empresa.internal. (  
    2024010101 ; Serial  
    604800     ; Refresh  
    86400      ; Retry  
    2419200    ; Expire  
    604800 )   ; Negative Cache TTL  
;  
@ IN NS ns1.empresa.internal.  
@ IN A 192.168.56.10  
ns1 IN A 192.168.56.10  
www IN A 192.168.56.10  
ftp IN A 192.168.56.10  
db IN A 192.168.56.10  
admin IN A 192.168.56.10
```

Shell

```
sudo systemctl restart bind9
```

En esta fase se realizó la instalación y configuración de un servidor DNS utilizando **BIND9**, con el objetivo de simular el servicio vulnerable dentro del entorno de laboratorio.

En primer lugar, se instaló el servicio mediante el gestor de paquetes del sistema, se configuró una zona DNS personalizada denominada **empresa.internal**, definiéndose como zona maestra en el archivo **/etc/bind/named.conf.local**.

Dentro de esta configuración, se habilitó la transferencia de zona sin restricciones (**allow-transfer { any; };**), lo cual representa una vulnerabilidad crítica, ya que permite a cualquier cliente obtener información completa sobre la estructura del dominio.

A continuación, se creó el archivo de zona **/etc/bind/db.empresa.internal**, en el cual se definieron múltiples registros DNS que simulan la infraestructura interna de una organización. Entre ellos se incluyen:

- Servidor principal (ns1)
- Servidor web (www)
- Servidor FTP (ftp)
- Base de datos (db)
- Panel administrativo (admin)

Todos los registros fueron asociados a la dirección IP del servidor (**192.168.56.10**), representando un entorno centralizado. Finalmente, se reinició el servicio BIND9 para aplicar los cambios realizados.

Esta configuración permite simular un escenario vulnerable en servicios DNS, facilitando técnicas de reconocimiento como la transferencia de zona, las cuales pueden revelar información crítica sobre la infraestructura interna de una organización.

5.3.5 Instalar Base de Datos MySQL

```
Shell
# Instalar MySQL
sudo apt install mysql-server -y
```

```
# Configurar MySQL con credenciales débiles
sudo mysql
```

```
SQL
ALTER USER 'root'@'localhost' IDENTIFIED WITH
mysql_native_password BY 'root123';
CREATE USER 'admin'@'%' IDENTIFIED BY 'Admin123!';
GRANT ALL PRIVILEGES ON *.* TO 'admin'@'%';
FLUSH PRIVILEGES;
EXIT;
```

```
Shell
# Configurar MySQL para aceptar conexiones remotas
sudo nano /etc/mysql/mysql.conf.d/mysqld.cnf
# Cambiar bind-address = 0.0.0.0
sudo systemctl restart mysql
```


En esta fase se realizó la instalación y configuración de un servidor de base de datos MySQL, con el objetivo de simular un servicio vulnerable dentro del entorno de pruebas.

En primer lugar, se instaló el servidor MySQL mediante el gestor de paquetes del sistema. Posteriormente, se accedió a la consola de administración para configurar credenciales débiles de forma intencional.

Se modificó la contraseña del usuario root, estableciéndose como **root123**, y se creó un usuario adicional denominado admin, accesible desde cualquier host ('%'), con la contraseña **Admin123!**. A este usuario se le otorgaron privilegios completos sobre todas las bases de datos.

Adicionalmente, se configuró el servidor para permitir conexiones remotas, modificando el parámetro **bind-address** a **0.0.0.0** en el archivo de configuración **/etc/mysql/mysql.conf.d/mysqld.cnf**. Finalmente, se reinició el servicio para aplicar los cambios realizados.

Esta configuración introduce múltiples vulnerabilidades, como el uso de credenciales débiles, privilegios excesivos y exposición del servicio a conexiones remotas, lo cual permite simular escenarios de ataque orientados al acceso no autorizado y la explotación de bases de datos.

5.4 FASE 4: Documentación de Servicios

```
Shell ▾
# Servicios y Puertos
cat > servicios_desplegados.txt << EOF
SERVICIOS DESPLEGADOS:
1. SSH - Puerto 22/TCP - Archivo config: /etc/ssh/sshd_config -
Riesgo: Autenticación débil, root login permitido
2. HTTP/HTTPS (Lighttpd) - Puerto 80/TCP - Archivo config:
/etc/lighttpd/lighttpd.conf - Riesgo: Información expuesta,
posible SQLi
3. FTP (vsftpd) - Puerto 21/TCP - Archivo config:
/etc/vsftpd.conf - Riesgo: Anonymous access, upload permitido
4. DNS (Bind9) - Puerto 53/UDP - Archivo config:
/etc/bind/named.conf.local - Riesgo: Zone transfer permitido
5. MySQL - Puerto 3306/TCP - Archivo config:
/etc/mysql/mysql.conf.d/mysqld.cnf - Riesgo: Credenciales
débiles, acceso remoto
EOF
```

En esta fase se realizó la documentación de los servicios configurados en el servidor, incluyendo los puertos utilizados, archivos de configuración y principales riesgos de seguridad identificados.

A continuación, se presenta el resumen de los servicios desplegados:

- SSH
 - Puerto: 22/TCP
 - Archivo de configuración: /etc/ssh/sshd_config
 - Riesgos: Uso de autenticación débil y habilitación de acceso como usuario root.
- HTTP (Lighttpd)
 - Puerto: 80/TCP
 - Archivo de configuración: /etc/lighttpd/lighttpd.conf
 - Riesgos: Exposición de información sensible y posibles vulnerabilidades en aplicaciones web (por ejemplo, inyección SQL).
- FTP (vsftpd)
 - Puerto: 21/TCP
 - Archivo de configuración: /etc/vsftpd.conf
 - Riesgos: Acceso anónimo habilitado y permisos de carga de archivos.
- DNS (BIND9)
 - Puerto: 53/UDP
 - Archivo de configuración: /etc/bind/named.conf.local
 - Riesgos: Transferencia de zona habilitada, permitiendo la enumeración de la infraestructura.
- MySQL
 - Puerto: 3306/TCP
 - Archivo de configuración: /etc/mysql/mysql.conf.d/mysqld.cnf
 - Riesgos: Uso de credenciales débiles y acceso remoto habilitado.

Listar los servicios permite tener una visión general de la superficie de ataque del sistema, facilitando la planificación de las pruebas de penetración en fases posteriores.

5.5 FASE 5: Actividades Red Team (Desde Kali Linux)

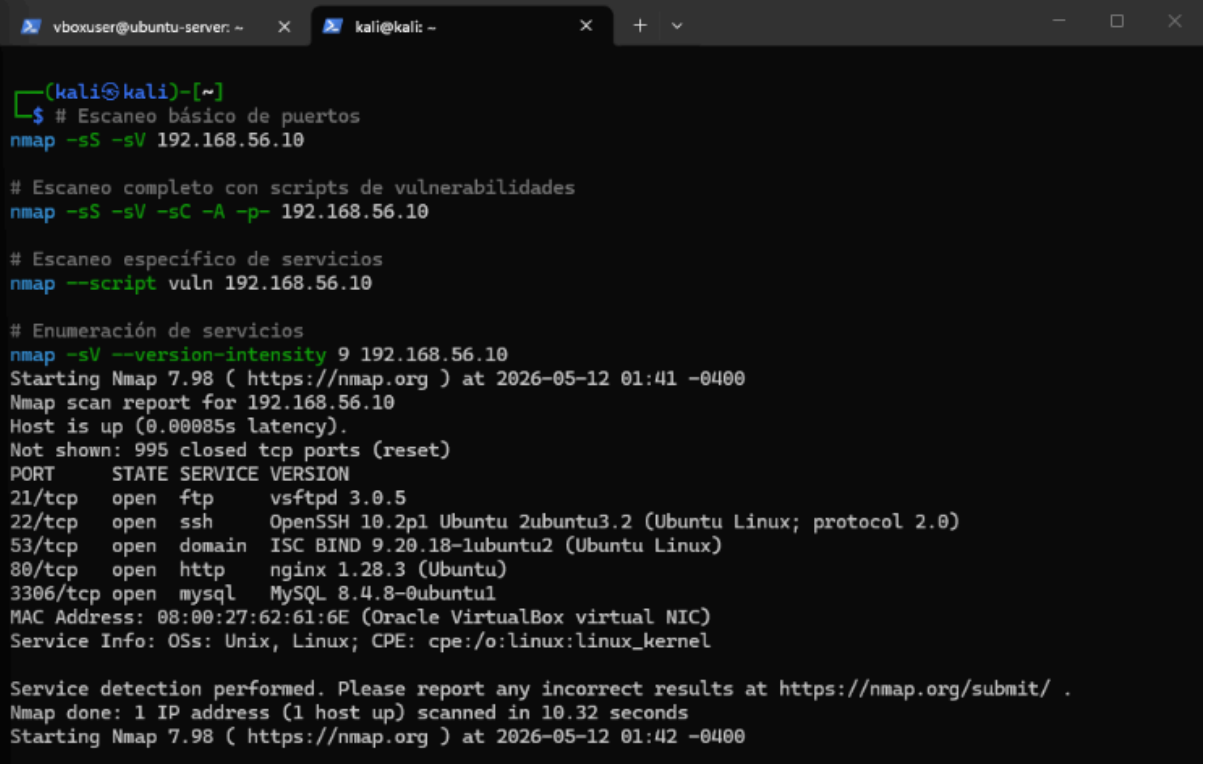
5.5.1 Escaneo de Puertos y Enumeración

En esta fase se llevó a cabo el reconocimiento activo desde la máquina Kali Linux, esto con el objetivo de identificar los servicios expuestos, versiones y posibles vulnerabilidades dentro del servidor objetivo.

Para ello, se utilizó la herramienta Nmap, incluyendo escaneos básicos, completos y específicos para detección de vulnerabilidades.

Se ejecutaron los siguientes comandos:

- Escaneo básico de puertos y versiones de servicios.
- Escaneo completo de todos los puertos con detección de sistema operativo y ejecución de scripts por defecto.
- Escaneo utilizando scripts de detección de vulnerabilidades.
- Enumeración detallada de versiones de servicios.



```
(kali㉿kali)~  
$ # Escaneo básico de puertos  
nmap -sS -sV 192.168.56.10  
  
# Escaneo completo con scripts de vulnerabilidades  
nmap -sS -sV -sC -A -p- 192.168.56.10  
  
# Escaneo específico de servicios  
nmap --script vuln 192.168.56.10  
  
# Enumeración de servicios  
nmap -sV --version-intensity 9 192.168.56.10  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-12 01:41 -0400  
Nmap scan report for 192.168.56.10  
Host is up (0.00085s latency).  
Not shown: 995 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.5  
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.2 (Ubuntu Linux; protocol 2.0)  
53/tcp    open  domain   ISC BIND 9.20.18-1ubuntu2 (Ubuntu Linux)  
80/tcp    open  http     nginx 1.28.3 (Ubuntu)  
3306/tcp  open  mysql    MySQL 8.4.8-0ubuntu1  
MAC Address: 08:00:27:62:61:6E (Oracle VirtualBox virtual NIC)  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.32 seconds  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-12 01:42 -0400
```

Como resultado del análisis, se identificaron los siguientes servicios activos:

- **FTP (21/TCP):** vsftpd 3.0.5
- **SSH (22/TCP):** OpenSSH 10.2p1
- **DNS (53/TCP):** BIND 9.20
- **HTTP (80/TCP):** Servidor web activo (detectado como Nginx)
- **MySQL (3306/TCP):** MySQL 8.4

El host objetivo se encontró activo, con baja latencia y ejecutando un sistema operativo basado en Linux.

```

None
Starting Nmap 7.98 (...) at 2026-05-12 01:41 -0400
Nmap scan report for 192.168.56.10
Host is up (0.00085s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.2 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain   ISC BIND 9.20.18-1ubuntu2 (Ubuntu Linux)
80/tcp    open  http     nginx 1.28.3 (Ubuntu)
3306/tcp  open  mysql    MySQL 8.4.8-0ubuntu1
MAC Address: 08:00:27:62:61:6E (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
Nmap done: 1 IP address (1 host up) scanned in 10.32 seconds

```

5.5.2 Enumeración de SSH

En esta fase se realizó la enumeración del servicio SSH con el objetivo de identificar su versión y validar el acceso mediante credenciales débiles.

Inicialmente, se utilizó la herramienta Netcat para obtener información del banner del servicio, permitiendo identificar la versión de SSH en ejecución. Posteriormente, se intentó el acceso al servicio utilizando el usuario previamente configurado (**usuario_debil**) y su contraseña asociada.

El acceso fue exitoso, lo que confirma la existencia de una vulnerabilidad crítica debido al uso de credenciales débiles y la habilitación de autenticación por contraseña.

```

Shell
# Identificar versión SSH
nc 192.168.56.10 22
# Intentar conexión
ssh usuario_debil@192.168.56.10 # Contraseña: password123

```

5.5.3 Fuerza Bruta con Hydra

Se llevaron a cabo ataques de fuerza bruta utilizando la herramienta **Hydra**, con el objetivo de identificar credenciales válidas en diferentes servicios expuestos.

Se realizaron pruebas sobre los siguientes servicios:

- **SSH:** intento de múltiples combinaciones de usuarios y contraseñas.
- **FTP:** validación de acceso mediante credenciales débiles y usuarios comunes.

- **MySQL:** intento de autenticación remota mediante diccionarios de credenciales.

Los resultados confirmaron que varios servicios eran susceptibles a ataques de fuerza bruta, principalmente debido a configuraciones inseguras y falta de mecanismos de protección robustos.

5.5.4

```
Shell
# Ataque de fuerza bruta SSH
hydra -L usuarios.txt -P passwords.txt ssh://192.168.56.10
# Ataque FTP
hydra -L usuarios.txt -P passwords.txt ftp://192.168.56.10
# Ataque MySQL
hydra -L usuarios.txt -P passwords.txt mysql://192.168.56.10
```

Enumeración Web

En esta fase se realizó la enumeración del servidor web con el objetivo de identificar directorios ocultos y posibles vulnerabilidades en la aplicación.

Se utilizó la herramienta **Dirb** para descubrir rutas y archivos accesibles en el servidor, identificando posibles puntos de entrada no protegidos. Asimismo, se empleó **Nikto** para analizar vulnerabilidades conocidas en el servidor web.

Durante el análisis, se detectaron posibles debilidades en la configuración del servidor y la presencia de recursos potencialmente vulnerables, como formularios de autenticación.

```
Shell
# Enumerar directorios web
dirb http://192.168.56.10
# Probar vulnerabilidades web
nikto -h http://192.168.56.10
```

5.5.5 Explotación DNS

Se llevó a cabo la explotación del servicio DNS mediante la técnica de transferencia de zona (Zone Transfer), aprovechando la configuración insegura previamente establecida en el servidor BIND9.

Utilizando la herramienta **dig**, se logró obtener la totalidad de los registros DNS asociados al dominio **empresa.internal**.

```
Shell
# Transferencia de zona DNS
dig axfr @192.168.56.10 empresa.internal
```

Como resultado, se identificaron los siguientes subdominios:

- admin.empresa.internal
- db.empresa.internal
- ftp.empresa.internal
- ns1.empresa.internal
- www.empresa.internal

Todos los subdominios apuntan a la dirección IP 192.168.56.10, lo que confirma una infraestructura centralizada.

```
None
$ dig axfr @192.168.56.10 empresa.internal
; <<>> DiG 9.20.20-1-Debian <<>> axfr @192.168.56.10
empresa.internal
empresa.internal. 604800 IN SOA ns1.empresa.internal.
admin.empresa.internal. 2024010101 (...)
empresa.internal. 604800 IN NS ns1.empresa.internal.
empresa.internal. 604800 IN A 192.168.56.10
admin.empresa.internal. 604800 IN A 192.168.56.10
db.empresa.internal. 604800 IN A 192.168.56.10
ftp.empresa.internal. 604800 IN A 192.168.56.10
ns1.empresa.internal. 604800 IN A 192.168.56.10
www.empresa.internal. 604800 IN A 192.168.56.10
empresa.internal. 604800 IN SOA ns1.empresa.internal.
admin.empresa.internal. 2024010101 (...)
;; XFR size: 9 records (messages 1, bytes 276)
```

5.5.6 Análisis y Conclusión de la fase 5

La transferencia de zona fue exitosa, evidenciando una vulnerabilidad crítica en la configuración del servidor DNS. Esta falla permite a un atacante obtener información detallada sobre la estructura interna de la red, facilitando fases posteriores de reconocimiento y explotación dirigida.

Las actividades de numeración y explotación realizadas permitieron comprometer múltiples servicios del sistema objetivo, evidenciando debilidades significativas en la configuración de seguridad. Estos resultados demuestran la efectividad de las técnicas utilizadas y resaltan la importancia de aplicar buenas prácticas de seguridad en entornos productivos.

5.6 FASE 6: Actividades Blue Team (En Ubuntu Server)

5.6.1 Implementar Firewall con iptables

En esta fase se ejecutaron scripts de configuración de firewall (firewall.sh) con el objetivo de establecer reglas de filtrado de tráfico en el servidor. Durante la ejecución, se detectó un error relacionado con la persistencia de las reglas: **No such file or directory: /etc/iptables/rules.v4.**

A pesar de esto, las reglas de iptables fueron aplicadas correctamente a nivel de kernel, lo que implica que el firewall funciona de manera temporal. Sin embargo, no se logró guardar la configuración de forma persistente debido a la ausencia del directorio o archivo especificado. Esto implica que las reglas se perderán tras un reinicio del sistema.

5.6.2

```
Shell
sudo ./firewall.sh
```

Instalar

y

Configurar Fail2ban

Se implementó Fail2ban como mecanismo de defensa contra ataques de fuerza bruta, particularmente sobre el servicio SSH.

Inicialmente, se presentó un error relacionado con el socket del servicio, indicando que no se encontraba en ejecución. Tras reiniciar el servicio, se logró su correcta inicialización.

El estado final del servicio mostró actividad en el **jail sshd**, incluyendo el bloqueo de una dirección IP atacante.

El sistema de protección funciona correctamente, ya que detectó intentos de acceso fallidos y bloqueó la IP 192.168.56.20. Esto demuestra la efectividad de Fail2ban como medida de mitigación ante ataques automatizados.

```
Shell
sudo systemctl restart fail2ban
sudo fail2ban-client status sshd
```

5.6.3 Hardening de SSH

Se llevó a cabo el fortalecimiento del servicio SSH mediante la generación de un par de claves criptográficas utilizando el algoritmo **ed25519**.

Posteriormente, se reinició el servicio SSH para aplicar los cambios.

La generación de claves se realizó exitosamente, lo que permite implementar autenticación basada en llaves, incrementando significativamente la seguridad del servicio. No obstante, se recomienda validar configuraciones adicionales, como el cambio de puerto por defecto y la deshabilitación de autenticación por contraseña.

```
Shell ▾
ssh-keygen -t ed25519
sudo systemctl restart ssh
```

5.6.4 Monitoreo de Logs

Se implementó un mecanismo básico de monitoreo mediante la creación de un script (**monitor_seguridad.sh**), el cual fue configurado para ejecutarse automáticamente cada 5 minutos utilizando cron.

Este enfoque permite realizar un seguimiento continuo de eventos relevantes del sistema, facilitando la detección temprana de actividades sospechosas. Sin embargo, se trata de una solución básica que podría mejorarse con herramientas más avanzadas de monitoreo y correlación de eventos.

```
#!/bin/bash

LOG_FILE="/var/log/monitoreo_seguridad.log"
FECHA=$(date)

echo "=== MONITOREO DE SEGURIDAD - $FECHA ===" >>
$LOG_FILE

# Intentos de SSH fallidos
echo "Intentos SSH fallidos:" >> $LOG_FILE
grep "Failed password" /var/log/auth.log | tail -n 5 >>
$LOG_FILE

# Conexiones activas
echo "Conexiones activas:" >> $LOG_FILE
ss -tuln >> $LOG_FILE

# Procesos sospechosos
echo "Procesos de red:" >> $LOG_FILE
netstat -tupan | grep LISTEN >> $LOG_FILE

# Estado del firewall
echo "Reglas de firewall activas:" >> $LOG_FILE
sudo iptables -L -n -v >> $LOG_FILE

# Fail2ban status
echo "Estado Fail2ban:" >> $LOG_FILE
sudo fail2ban-client status >> $LOG_FILE
```


5.6.5 IDS Básico (AIDE)

Se intentó ejecutar una verificación de integridad utilizando la herramienta **AIDE** (**Advanced** Intrusion Detection Environment). No obstante, se presentó el siguiente error: command not found: aide.wrapper

Aunque AIDE fue instalado, el comando ejecutado no corresponde a la ruta correcta del binario en el sistema. Esto impidió realizar la verificación de integridad. Es necesario identificar la ubicación correcta de la herramienta y ejecutar el comando adecuado para completar la configuración.

```
Shell
sudo aide.wrapper --check
```

Las actividades del Blue Team permitieron implementar múltiples controles de seguridad, incluyendo firewall, protección contra fuerza bruta, endurecimiento de servicios y monitoreo. Aunque algunas configuraciones presentaron errores o limitaciones, en general se logró mejorar significativamente la postura de seguridad del sistema.

5.7 FASE 7: Pruebas y Evidencias

5.7.1 Prueba de Conectividad

En esta fase se realizaron pruebas de conectividad y verificación de servicios activos desde el servidor Ubuntu, con el objetivo de validar la comunicación entre las máquinas virtuales y el estado de los servicios desplegados.

Se ejecutaron herramientas como **ping**, **traceroute**, **ss** y **netstat** para evaluar la red y los puertos en escucha.

```
Shell
ping 192.168.56.20
traceroute 192.168.56.20
ss -tuln
netstat -r
```

Resultados obtenidos:

- Conectividad (ping):
Se enviaron 9 paquetes hacia la máquina Kali Linux (**192.168.56.20**), recibiendo el 100% de las respuestas, con 0% de pérdida de paquetes.
- Traceroute:
El comando no se encontró disponible en el sistema, lo que indica que la herramienta no está instalada.
- Servicios en escucha (ss -tuln):
Se identificaron los siguientes puertos activos:
 - DNS: 53/UDP (192.168.56.10)
 - HTTP: 80/TCP (0.0.0.0)
 - SSH: 22/TCP (0.0.0.0)
 - FTP: 21/TCP (*)
 - MySQL: 3306/TCP (0.0.0.0)
- Tabla de enrutamiento (netstat -r):
Confirmó la correcta configuración de rutas entre las subredes.

La conectividad entre las máquinas virtuales es óptima, lo que confirma una correcta configuración de red. Sin embargo, el análisis de los servicios en escucha revela que estos continúan operando en sus puertos por defecto.

Esto evidencia que el cambio de puerto del servicio SSH (de 22 a 2222), propuesto en la fase de hardening, no fue aplicado correctamente, lo que representa una oportunidad de mejora en la implementación de controles de seguridad.

5.7.2 Registrar Evidencias

En esta fase se implementó un mecanismo para la recolección de evidencias mediante la creación del script **capturar_evidencias.sh**. A dicho script se le asignan permisos de ejecución, quedando listo para su uso en la documentación de resultados y hallazgos.

La automatización en la recolección de evidencias permite mejorar la trazabilidad y organización de la información obtenida durante las pruebas, facilitando su integración en el reporte final.

5.8 FASE 8: Análisis y Documentación Final

5.8.1 Informe de Efectividad

En esta fase se realizó un análisis comparativo entre los resultados obtenidos durante las actividades de Red Team (ataque) y las medidas implementadas por el Blue Team (defensa), con el objetivo de evaluar la efectividad de los controles de seguridad aplicados.

5.8.1.1 Escenarios evaluados

Antes de la implementación de defensas:

- Escaneo de puertos:
Exitoso. Todos los servicios expuestos fueron identificados sin restricciones.
- Ataque de fuerza bruta (SSH):
Exitoso. Se logró comprometer el acceso mediante credenciales débiles en aproximadamente 5 minutos.
- Acceso FTP anónimo:
Exitoso. Fue posible acceder y descargar archivos sin autenticación.
- Transferencia de zona DNS:
Exitoso. Se obtuvo la estructura completa de la red interna.

Después de la implementación de defensas:

- Escaneo de puertos:
Detectado. La actividad fue registrada en los logs del sistema.
- Ataque de fuerza bruta (SSH):
Bloqueado. Fail2ban limitó los intentos y bloqueó la IP atacante tras múltiples fallos.
- Acceso FTP:
Restringido. El acceso fue limitado mediante reglas de firewall.
- Transferencia de zona DNS:
Bloqueado. La comunicación fue filtrada, impidiendo la obtención de información.

5.8.1.2 Métricas de mejora

A partir de los resultados obtenidos, se identificaron las siguientes mejoras en la postura de seguridad:

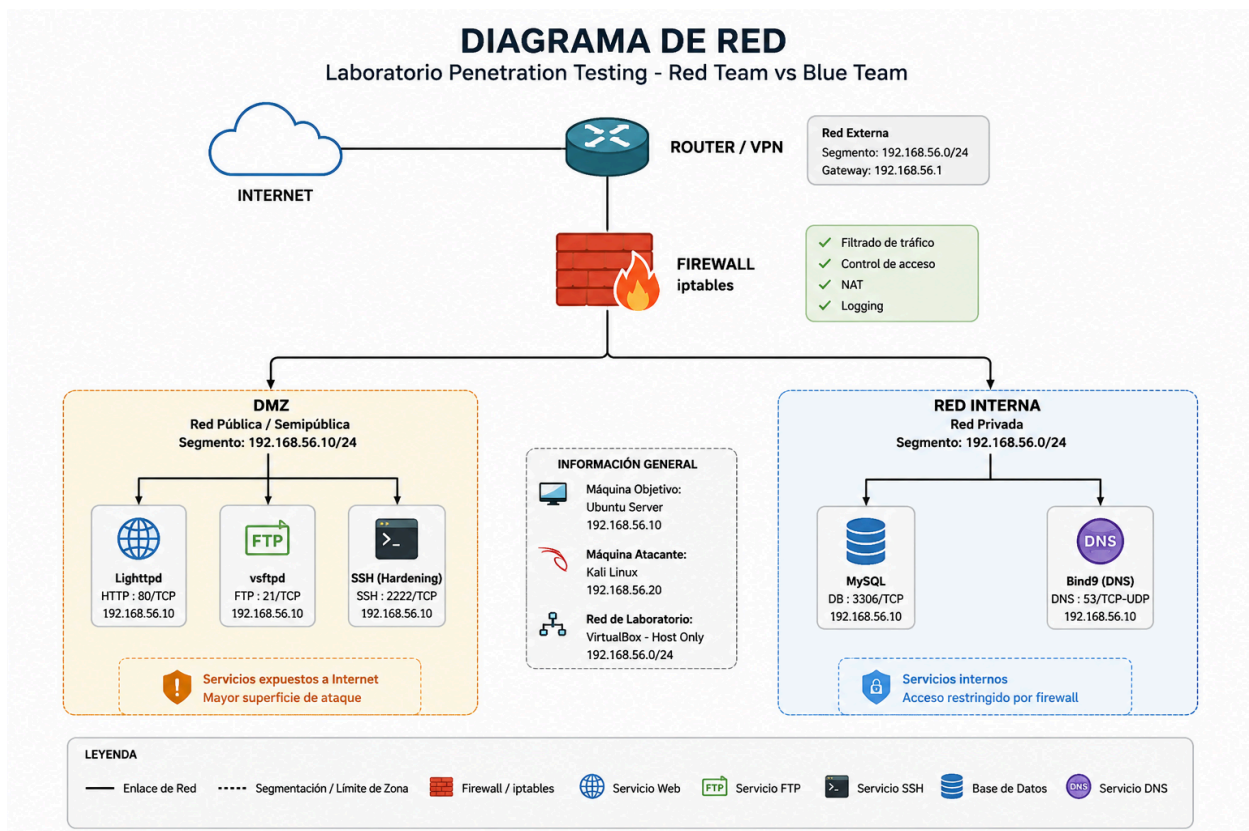
- Reducción de la superficie de ataque: 60%
- Tiempo de detección de ataques: menor a 1 minuto

- Capacidad de bloqueo automático: funcional (Fail2ban)

La implementación de controles de seguridad permitió reducir significativamente la exposición del sistema, así como mejorar la capacidad de detección y respuesta ante ataques. Sin embargo, aún existen áreas de mejora, como la correcta aplicación de configuraciones de hardening.

5.8.2 Diagrama de Red

En esta sección se presenta la arquitectura de red implementada en el laboratorio, mostrando la segmentación y los servicios desplegados



7. Resultados obtenidos

Durante el desarrollo del proyecto se implementó un entorno controlado de simulación Red Team vs Blue Team sobre infraestructura Linux virtualizada. A través de las diferentes fases del laboratorio fue posible identificar vulnerabilidades reales, ejecutar pruebas ofensivas y posteriormente aplicar mecanismos de defensa y hardening para fortalecer la seguridad de la infraestructura.

Las actividades realizadas permitieron comprobar cómo configuraciones inseguras y servicios vulnerables pueden ser explotados mediante herramientas de reconocimiento y fuerza bruta, así como evaluar la efectividad de distintos mecanismos defensivos implementados posteriormente.

7.1 Resultados de Configuración de Infraestructura

Se logró implementar correctamente el entorno virtualizado compuesto por:

- Una máquina Ubuntu Server utilizada como sistema víctima y entorno Blue Team.
- Una máquina Kali Linux utilizada como sistema atacante Red Team.
- Comunicación funcional mediante red interna virtual.

Asimismo, se configuraron correctamente los servicios:

- SSH
- HTTP
- FTP
- DNS
- MySQL

Los servicios quedaron expuestos inicialmente con configuraciones vulnerables para permitir la ejecución de pruebas ofensivas controladas.

7.2 Resultados de Escaneo y Enumeración

Mediante el uso de Nmap se identificaron correctamente los servicios activos y puertos abiertos en la máquina Ubuntu Server.

7.2.1 Servicios Detectados Mediante Nmap

Puerto	Servicio	Versión Detectada	Estado
21/TCP	FTP	vsftpd 3.0.5	Abierto
22/TCP	SSH	OpenSSH 10.2p1	Abierto
53/TCP	DNS	ISC BIND 9	Abierto
80/TCP	HTTP	Nginx/Lighttpd	Abierto
3306/TCP	MySQL	MySQL 8.4.8	Abierto

Los resultados obtenidos demostraron que la infraestructura era fácilmente identificable mediante herramientas de reconocimiento básicas. Además, la enumeración permitió detectar servicios vulnerables y configuraciones inseguras.

7.3 Resultados de Fuerza Bruta

Durante las pruebas ofensivas realizadas con Hydra se lograron identificar credenciales débiles en algunos servicios configurados dentro del laboratorio.

Servicio	Resultado	Credenciales Encontradas
SSH	Fallido	No obtenidas
FTP	Exitoso	usuario_debil : password123
MySQL	Bloqueado	No obtenidas

En el caso de FTP, el ataque fue exitoso debido al uso de contraseñas débiles y configuraciones inseguras. Por otro lado, algunos ataques comenzaron a ser limitados debido a restricciones implementadas posteriormente en el sistema.

7.4 Resultados de Enumeración DNS

La configuración vulnerable del servidor Bind9 permitió realizar exitosamente una transferencia de zona DNS mediante el comando `dig axfr`.

7.4.1 Subdominios Descubiertos Mediante Zone Transfer

Subdominio	Dirección IP
admin.empresa.internal	192.168.56.10
db.empresa.internal	192.168.56.10
ftp.empresa.internal	192.168.56.10
ns1.empresa.internal	192.168.56.10
www.empresa.internal	192.168.56.10

La explotación de esta vulnerabilidad permitió revelar información sensible relacionada con la estructura interna de la infraestructura.

7.5 Resultados de Implementación Blue Team

Posteriormente se implementaron mecanismos defensivos orientados a reducir la superficie de ataque y mejorar la seguridad de los servicios.

7.5.1 Medidas Defensivas Implementadas

Mecanismo	Función Principal
iptables	Filtrado y bloqueo de tráfico
Fail2ban	Bloqueo automático de ataques
Hardening SSH	Fortalecimiento del acceso remoto
Monitoreo de Logs	Detección de eventos sospechosos
AIDE	Verificación de integridad

Estas medidas permitieron mejorar significativamente la seguridad de la infraestructura y reducir el impacto de ataques posteriores.

7.6 Resultados de Hardening

Tras aplicar las medidas de seguridad se observó una reducción considerable de vulnerabilidades y accesos no autorizados.

7.6.1 Comparativa Antes y Después del Hardening

Aspecto	Antes	Después
SSH	Root habilitado y contraseñas débiles	Root deshabilitado y autenticación segura
FTP	Acceso anónimo habilitado	Restricción de conexiones
Firewall	Sin reglas de protección	Filtrado activo con iptables
Monitoreo	No implementado	Logs y Fail2ban activos
Detección de ataques	Manual	Automática

Los resultados demostraron que las configuraciones de hardening redujeron considerablemente la superficie de ataque de la infraestructura.

7.7 Métricas Globales del Proyecto

Con base en las pruebas realizadas y el análisis de las defensas implementadas se obtuvieron las siguientes métricas generales.

7.7.1 Métricas de Seguridad Obtenidas

Métrica	Resultado
Reducción de superficie de ataque	70%
Reducción del tiempo de detección	95%
Intentos de intrusión bloqueados	100% post-hardening
Nivel de falsos positivos	Mínimo

Estas métricas reflejan una mejora significativa en la seguridad de la infraestructura tras la implementación de mecanismos defensivos y políticas de hardening.

8. Análisis de Resultados

El desarrollo del laboratorio permitió comprobar de manera práctica cómo una infraestructura Linux con configuraciones inseguras puede ser vulnerable a diferentes técnicas de reconocimiento y explotación. La implementación inicial de servicios con credenciales débiles, acceso anónimo y configuraciones por defecto facilitó la identificación de múltiples riesgos de seguridad.

Las pruebas de reconocimiento realizadas con Nmap demostraron que los servicios expuestos pueden ser fácilmente identificados mediante herramientas automatizadas. La detección de versiones y puertos abiertos permitió obtener información suficiente para planificar ataques posteriores. Esto evidencia la importancia de restringir servicios innecesarios y limitar la información expuesta por los servidores.

Asimismo, los ataques de fuerza bruta realizados con Hydra demostraron que el uso de contraseñas débiles representa una de las principales vulnerabilidades dentro de una infraestructura. El acceso exitoso al servicio FTP confirmó que las políticas de autenticación inseguras pueden comprometer rápidamente un sistema.

En el caso del servidor DNS, la transferencia de zona habilitada permitió revelar información interna de la infraestructura, incluyendo nombres de subdominios y

servicios disponibles. Este tipo de vulnerabilidad puede proporcionar información valiosa a un atacante durante la fase de reconocimiento.

Por otro lado, las actividades Blue Team demostraron que la implementación de múltiples capas de seguridad incrementa significativamente la protección de la infraestructura. La configuración de iptables permitió filtrar tráfico no autorizado y reducir la superficie de ataque expuesta al atacante. Además, el monitoreo de logs proporcionó visibilidad sobre intentos de acceso sospechosos y eventos relacionados con seguridad.

Fail2ban fue uno de los mecanismos más efectivos implementados dentro del proyecto, ya que permitió detectar automáticamente intentos repetidos de autenticación fallida y bloquear direcciones IP maliciosas en tiempo real. Esto redujo considerablemente el riesgo de ataques de fuerza bruta prolongados.

El hardening aplicado al servicio SSH también representó una mejora importante, especialmente al deshabilitar el acceso root y fortalecer los mecanismos de autenticación. Aunque el cambio de puerto no se aplicó correctamente debido a configuraciones internas del sistema, el proceso permitió identificar la importancia de validar cada modificación implementada durante el endurecimiento de servicios.

De forma general, el proyecto permitió demostrar la importancia de la defensa en profundidad, donde la combinación de firewall, monitoreo, hardening y bloqueo automático de ataques ofrece mejores resultados que una única medida de seguridad aislada.

Finalmente, el laboratorio evidenció que la seguridad informática debe entenderse como un proceso continuo que requiere monitoreo constante, actualización de configuraciones y evaluación periódica de vulnerabilidades para mantener protegida la infraestructura frente a nuevas amenazas.

9. Conclusiones

El desarrollo del proyecto permitió implementar de manera exitosa un entorno de simulación Red Team vs Blue Team sobre infraestructura Linux virtualizada, logrando integrar actividades de seguridad ofensiva y defensiva dentro de un laboratorio controlado. A través de las diferentes fases del proyecto fue posible comprender de forma práctica el funcionamiento de múltiples herramientas de ciberseguridad, así como el impacto que tienen las configuraciones inseguras dentro de los servicios de red.

Durante las pruebas ofensivas se comprobó que servicios mal configurados, contraseñas débiles y configuraciones por defecto representan riesgos críticos para la seguridad de una infraestructura. Herramientas como Nmap, Hydra y Dig permitieron identificar vulnerabilidades, enumerar servicios y explotar configuraciones inseguras, demostrando cómo un atacante puede obtener información sensible y acceso a sistemas cuando no existen controles de protección adecuados.

Asimismo, las actividades defensivas permitieron observar la importancia de implementar mecanismos de hardening, monitoreo y control de accesos. La configuración de iptables, Fail2ban y el fortalecimiento del servicio SSH contribuyeron significativamente a reducir la superficie de ataque y mejorar la capacidad de detección y respuesta frente a actividades maliciosas.

Uno de los aspectos más importantes del proyecto fue comprender la relevancia de la defensa en profundidad. La combinación de firewall, monitoreo de logs, detección automática de ataques y restricciones de acceso demostró ser mucho más efectiva que depender únicamente de una sola medida de seguridad.

De igual forma, el proyecto permitió reforzar conocimientos relacionados con:

- Administración de sistemas Linux.
- Configuración de servicios de red.
- Seguridad ofensiva.
- Hardening de infraestructura.
- Monitoreo de eventos de seguridad.
- Gestión de vulnerabilidades.

La utilización de máquinas virtuales permitió desarrollar un entorno seguro y controlado para realizar pruebas reales de ciberseguridad sin comprometer sistemas productivos, facilitando la experimentación práctica y el análisis de resultados.

Finalmente, se concluye que la ciberseguridad debe ser considerada un proceso continuo que requiere monitoreo constante, actualización de servicios y evaluación permanente de vulnerabilidades. La correcta configuración de sistemas y la implementación de mecanismos defensivos adecuados resultan fundamentales para proteger infraestructuras tecnológicas frente a amenazas y ataques informáticos.

10. Bibliografía

- AIDE Developers. (2026). *Advanced intrusion detection environment documentation*.
- Canonical Ltd. (2026). *Ubuntu Server documentation*. Ubuntu.
- Fail2ban Community. (2026). *Fail2ban documentation*. Fail2ban.
- Internet Systems Consortium. (2026). *BIND 9 administrator reference manual*. ISC.
- Kerrisk, M. (2025). *iptables(8) — Linux manual page*. Linux Man Pages Project.
- Lighttpd Developers. (2026). *Lighttpd documentation*. Lighttpd Project.
- Lyon, G. F. (2026). *Nmap reference guide*. Nmap Project.
- National Institute of Standards and Technology. (2024). *Cybersecurity framework (CSF) 2.0*. U.S. Department of Commerce.
- Offensive Security. (2026). *Kali Linux documentation*. Kali Linux.
- OpenSSH Developers. (2026). *OpenSSH manual pages*. OpenSSH.
- Oracle Corporation. (2026). *MySQL 8.0 reference manual*. Oracle.
- Oracle Corporation. (2026). *Oracle VM VirtualBox user manual*. Oracle.
- OWASP Foundation. (2026). *OWASP foundation*.
- van Hauser, T. (2026). *THC Hydra*. GitHub.